

1. Protocoale de Autentificare

1. Autentificare

↓
verificarea identității
utilizatorului (parola)

Autorizare
↓
acces

Accounting
↓
urmărirea și
înreg. activităților utiliz.

2. Factori de autentificare

Cea ce utilizatorul
← cunoaște (parolă, PIN)
← deține (certificat digital, token)
← este (amprentă, voce)

Pt o autentificare sigură → combinarea a cel puțin 2 factori

3. Tipuri de autentificare

DIRECTĂ → fiecare sistem are o bază de date proprie pt autentificare
potrivită pt sisteme mici

INDIRECTĂ → utilizarea unei baze de date la comun
RADIUS,
TACACS+
LDAP
eficiență pt management centralizat.

4. Protocoale de autentificare

- a. Password Authentication Procedure (PAP)
- b. Challenge-Handshake Authentication Protocol (CHAP)
- c. Windows NT LAN Manager (NTLM)
- d. Kerberos
- e. Certificat digital
- f. Generatoare de parole de unică folosință
- g. Biometrice

PAP - transmiterea username-ului și parolei în clear ⇒ mesaj
IETF RFC 1334

CHAP - protocol în 3 pași
Provocare
Răspuns
Success/Failure

- parola nu circula niciodată prin rețea
- valoarea aleatoare (provocarea) trebuie să fie mereu ≠ pt evitarea atacurilor prin rețea

IETF RFC 1994

NTLM

- autentificare în Domeniul Windows
- domeniu = colecție de servicii
 - E-mail
 - File Sharing
 - Printing etc } administrate printr-un Domain Controller (DC)
- administrare centralizată - un singur cont pt un domeniu gestionat de DC
 - nu tb să ai cont pt fiecare server din domeniu
- oferă flexibilitate ridicată
 - administrare la nivel de grup
 - domenii multiple (încercare între domenii)
- toată lumea tb să aibă încredere în DC

Avantaje	Dezavantaje
- parola NU e trimisă în clar - parola e cunoscută NUMAI de DC - simplu și eficient dacă se folosesc parole sigure	- protocolul de autentificare tb repetat de fiecare server - DC - element critic (instalare Backup DC) - parolele slabe sau scurte pot fi sparte prin atacuri dicționar

KERBEROS

- dezvoltat în 1983 în proiectul Athena de la Massachusetts of Technology (MIT)
- autentificarea în rețea TCP/IP bazată pe sisteme UNIX
- alg. de criptare simetrică (AES)
- se bazează pe servicii de mediere oferite de un forț de încredere (KDC - Key Distribution Center)
- derivat din schema Needham și Schnerier
- VS (IETF RFC 1510, 1993) - versiune curentă
- Microsoft → a adoptat începând cu Windows 2000.
 - ↳ versiune extinsă → suport pt certificate digitale standard smart carduri

Kerberos KDC

- fiecare entitate are o cheie secretă master pe care o înregistrează la KDC
↳ derivată din parolă.
- fiecare acces securizat este mediat prin master ticket Kerberos

Dezavantaje

- * cheia master este folosită de fiecare dată când accesăm un server
→ trebuie emis un mai ticket de KDC
- * introducerea marei parole când se trimite cerere de emisie ticket
- * ~~se~~ cheia master trebuie ținută într-o memorie temporară (sus!)

Soluție: Ticket - Granting Ticket (TGT)

- ↳ un ticket special emis de KDC cu viață mai lungă (8-24 ore)
↳ introducem parola mai rar.

Replicarea KDC

- ↳ baza de date a KDC Master este transferată periodic către KDC Slave
base de date sunt read-only.

Autentificarea între realm-uri

- ↳ permite comunicarea securizată între diferite domenii

e) Autentificarea cu certificate digitale

ITU-T • ITU-T recomandată X.509

- infrastructuri de chei publice PKI
- Autoritatea de Certificare (CA) = entitate de încredere care garantează autenticitatea unei chei publice
- Autentificarea se realizează făcând dovada posesiei cheii private asociate cheii publice din certificat
- certificatul digital în sine nu e un factor de autentificare (e public și poate fi obținut de oricine)
↳ e folosit doar pt validarea datelor semnate.

Protocolul de autentificare X.509.

- one-way auth
- two-way auth
- three-way auth

One-way authentication

- un singur schimb de mesaje
- protocolul asigură * autentificarea lui A la B
* integritatea și originalitatea datelor (mesajul nu a fost trimis de mai multe ori).

Two-way auth

- 2 schimburi de mesaje
- prot. asigură în plus * autentificarea lui B la A
* integritatea și originalitatea mes. răsp.

Three-way auth

- 3 schimburi
- prot. asigură în plus: * evitarea atacurilor prin reținere în cazul în care ambele părți nu se pot sincroniza.

f) Generatoare de parole de unică folosință

- parolele - vulnerabile la o serie de atacuri
↳ pot fi interceptate sau ghicite/sparte

SOLUȚIE: parole de unică folosință

- nu sunt re-folosite dacă sunt interceptate
- RSA SecurID
- Vasco DIGPASS
- Gemalto / Safe Net eToken
- Google Authenticator

g) Metode Biometrice

Amprenta, voce, iris, geometria feței, mâinilor, etc.

Evaluarea metodelor de autentificare

Cerințe Organizaționale	Cerințe Utilizator	Costuri
- nivelul de securitate necesar - interoperabilitate - robustețe / scalabilitate - flexibilitate	- ușurință în folosire - portabil - multifuncțional	- cost de achiziție - de implementare - operare

2. Protocoale de Securitate la Nivel Retea

1. Retele ^{Private} Virtuale

- interconectarea componentelor unei rețele private cu ajutorul unei rețele publice (ex: Internet)

Utilizări - conectarea utilizatorilor remote

- interconectare sucursale
- ———— cu parteneri de afaceri

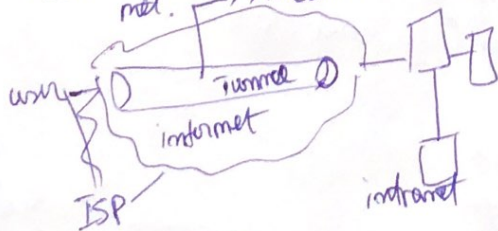
2. Tehnologii de tunelare a datelor

Tunelare = încapsularea datelor ca să fie transmise în siguranță prin rețeaua publică.

- Tipuri:
- Nivel 1 - PPTP, L2TP
 - Nivel 2 - IPsec
 - Nivel 3 - SSL

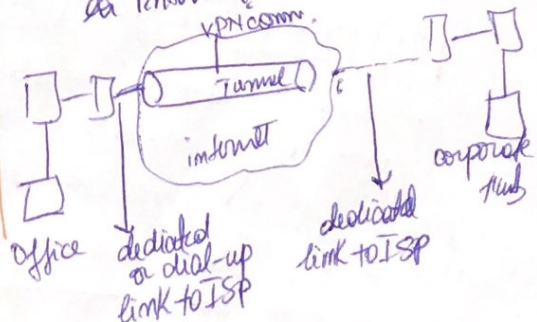
3. Remote Access VPN

- conectare de la distanță în LAN
- userul se conectează la Internet prin ISP-ul local
- userul stabilește un tunel prin Internet cu gateway-ul de acces în rețeaua locală
- costul VPN e de obicei legat de legătura locală la rețea → VPN Conn.



Site-to-Site

- interconectare sucursale, parteneri de afaceri
- tunelul se stabilește între gateway-uri
- costul similar cu cel al accesului la Internet



4. Avantaje VPN

- conectivitate globală.

- flexibilitate
- administrare ușoară - elimină necesitatea legăturii dedicate
- disponibilitate - riscul învechirii (acum + totul ISP)
- scalabilitate - conectarea unei noi sucursale la LAN și face doar prin conectarea la Internet și apoi configurarea tunelului

5. IPSEC

- extinde IPv4 cu funcționalități de securitate la Nivel 3+.
- protocoalele din nivelul superior (TCP, UDP) → au servicii de comunicație securizate
- stiva TCP/IP trebuie modificată pt a suporta IPsec.
a clientilor / gateway-univers

Arhitectura IPsec

Definită prin mai multe RFC-uri: 4301, 4302, 4303, 4305, 4306...

- probleme de interoperabilitate între diferite implementări

AH și ESP

AH - Authentication Header Protocol

- asigură INTEGRITATEA pachetelor și AUTENTIFICAREA originii datelor
- nr protocol = 51

ESP - Encapsulating Security Payload Protocol

- CONFIDENȚIALITATEA datelor + AUTENTIFICAREA originii datelor
- nr protocol = 50

Pot fi folosite independent sau separat.

Moduri de operare $\begin{cases} \text{tunel} \\ \text{transport} \end{cases}$

6. Security Association (SA)

= contract stabilit între cele 2 capete ale tunelului IPsec

- conține $\begin{cases} \text{parametri criptografici (alg, chei etc)} \\ \text{timp de viață} \end{cases}$

- SA sunt stocate într-o bază de date

- ~~Fiecare SA are un identificator propriu.~~
- Fiecare SA este identificat prin SPi (Security Parameters Index)

7. Internet Key Exchange

- gestionarea SA $\begin{cases} \text{manual} \\ \text{automat} \end{cases}$

ISAKMP $\leftarrow$ Internet Security Association and Key Management framework pt. gestionarea cheilor si SA.

IKE

- stabileste parametrii criptografici (alg de criptare)
- autentificare între entităţi (pre-shared Keys sau certificate digitale)
- stabilirea cheii de sesiune (Diffie-Hellman DH)
- foloseşte portul UDP 500 pt comunicaţie
- RFC 4306 (IKE v2)

Moduri de lucru

Faza 1: - negocierea unui ISAKMP SA iniţial

- Modul principal: 6 mesaje
- Modul agresiv: 3 mesaje
 - nu asigură protecţia identităţii

Modul principal $\nearrow$ pt stabilirea unui SA iniţial (ISAKMP SA)

Modul rapid - negocierea unui SA general (IPSec SA)

Faza 2: - negocierea unui IPSec SA general

- reînprospătarea cheilor de sesiune
- mod rapid.

IPSec SA se foloseşte pt transmiterea datelor până acesta expiră.
 $\downarrow$
după tb. negociat unul nou
 $\downarrow$
pt înnoire se foloseşte modul rapid.

Modul rapid

- schimb de mesaje criptate folosind cheia obţinută în faza 1
- negocierea parametrilor pt IPSec SA.
- 3 mesaje
- IPSec SA - bidirecţional (unul pt conexiunea de intrare şi unul pt ieşire)
- schimbarea periodică a cheilor $\Rightarrow$ Perfect Forward Secrecy

8. Perfect Forward Secrecy

- compromiterea unei sesiuni nu o afectează pe următoarea

9 Implementare IPsec VPN

1. Algoritmi recomandați - pt. criptare: 3DES, AES
- pt. integritate: SHA-2.

2. Provocări:

a) fragmentarea pachetelor (AH și ESP → dimensiunea pachetelor
→ performanța rețelei)

b) translații de adrese NAT (modifică pachetele IP
selon NAT înainte de IPsec)

⇒ IPsec NAT traversal (NAT-T)
(încapsularea pachetelor IPsec în UDP)

c) configurare firewall:

- AH - 51, ESP - 50

- IKE (UDP 500)

- IPsec NAT-T (UDP Port 4500)

d) L2TP/IPsec

- asignare adrese IP prin DHCP pt. clienții VPN

e) extensii de autentificare: (XAUTH)

- RADIUS, TACACS+, RSA SecurID.

Soluții:

- Cisco

- Juniper

- CheckPoint VPN-1

- Microsoft

- Linux: StrongSwan/OpenSwan

- FreeBSD: KAME, racoon, IKE daemon.

Net
Open

3. Protocoale de Securitate la Nivel Transport.

1. Protocolul SSL Secure Sockets Layer.

- dezvoltat de Netscape
- protocol de nivel 4+
- funcționare peste TCP și oțre comunicație securizată prin socket-uri
- aplicațiile trebuie modificate pt. a suporta SSL, d
dar stiva TCP/IP nu trebuie modificată

versiuni - SSL V3.0, TLS V1.0
V1.1
V1.2
V1.3.

2. Protocoale SSL

- SSL Handshake Protocol - negociază alg criptografici
 - schimbare chei
 - AUTENTICARE server, optional client
- SSL Record Protocol - transmite date, le fragmentează, le compresează
 - asigură AUTENTICARE + INTEGRITATE (cu MAC) (cu SHA 1)
 - le criptează (cu alg simetrice)
- SSL Change Cipher Spec Protocol - un mesaj ce indică sf. fazei handshake
- SSL Alert Protocol - mesaje de eroare

a) SSL Handshake Protocol

- Autentificarea entităților
 - certificate digitale
 - obligatoriu pt server, optional client.
- Mecanisme pt schimbul de chei
 - RSA - cheia secretă e criptată cu cheia publică a serverului
 - Fixed Diffie-Hellman: param DH sunt incluși într-un certificat digital
 - Ephemeral Diffie-Hellman: param DH generați alator și semnificați RSA/DSA
 - Anonymous Diffie-Hellman: param DH generați alator fără auth.
 - Interzesa - metode proprietară

Criptarea datelor

Cifruiri block - RC2-40
DES-40
DES-56
3DES-168
IDEA-128
Serpent-80

Cifruiri stream:

RC4-40

RC4-128

3. Protocolul TLS

- standardizare SSL creată de către IETF RFC 2246.

Îmbunătățiri față de SSL

1. suport pt mai alg. cript. → 3DES, AES, Camellia, GOST, SHA2
2. MAC (xor im bcd de 11)
3. generare de chei îmbunătățite PRF
4. mesaje de alertă adiționale
5. format optimizat al mesajelor
6. padding

4. Implementarea SSL / TLS

1. Certificate digitale - pt autentificare server/client
2. HTTPS pt securizarea tran. actiilor web
3. SSLizare - librării criptografice
 - BSAFE (RSA Security)
 - OpenSSL

5. Tipuri de certificate digitale

- Domain Validation (DV)
 - se verifică doar existența domeniului
 - p. rapid
- Organization Validation (OV)
 - se verifică și domeniului și organiz.
 - emis în câteva zile
- Extended Validation (EV)
 - verifică amănunțit domeniul + og.
 - în câteva săptăm.
- Certificate transparency
 - audit public al certificatelor

Rec: deserv. SSL, utilizare numai TLS

4. Protocole de Securitate la Nivel Aplicație

1. Pretty Good Privacy (PGP)

- Phil Zimmermann, 1991
- protejază e-mail-urile și fișierele stocate local

Caracteristici:

- folosește alg. cript. moderni
- cod sursă free
- funcționează pe multiple platforme (Windows, Unix, MacOS)
etc
- e un standard Internet

2. Servicii oferite

- ① Autentificare
- ② Confidențialitate
- ③ Compresie date
- ④ Compatibilitate cu e-mail-ul

Funcționalități importante

① Compresie date

- pt a reduce durata procesorilor și încălzirea rețelei
- se aplică înainte de criptare
(procesul de decriptare se complica)
- ZIP / UNZIP

② Compatibilitate e-mail

- mesajele semnate și criptate binar
- suportă numai msg text
- se folosește de conversia Radix 64

3. Gestionarea cheilor în PGP

- model Web of Trust - recomandări între utilizatori.
- inele de cheie $\left\{ \begin{array}{l} \text{Public Key Ring} \\ \text{Private} \end{array} \right.$
- distribuție:
 - floppy disk
 - e-mail (compusă de cheie pt valabilitate)
 - surse de chei PGP

4. Nivel de încredere PGP

- încredere în proprietar - setată manual
- încrederea în semnătură - automat de sistem
- legitimitatea cheii - suma încredinței în prop. care are semnătura

II S/MIME Secure / Multipurpose Internet Mail Extension

- standard elaborat de RSA Security
- securizarea mesajelor MIME
- servicii similare PGP (autentificare, confidențialitate etc)

1. MIME și limitările sale

- nu transmite obiecte binare
- nu suportă mesaje de dimensiuni mari
- nu are suport multilingvistic

REZOLVĂ

- multiple pt antetul mesajelor
- definește formate de conținut (multimediale)
- regulile codificării datelor pt a preveni modif. mesajelor

2. Tipuri de mesaje securizate în S/MIME

- enveloped data - mesaje criptate
- signed data - semnătură digitală + mesaje codificate Base 64
- clear signed data - semnătură digitală vizibilă
 - mesajul poate fi interpretat de clienți incompatibili (nu fol. S/MIME)
- signed & clear enveloped data

3. Algoritmi

Funcție hash - must: SHA-1
- should: (receiver) MD5

Signatură digitală - must: DSS
- should: RSA

Înveltoare cheii de sesiune - must: Diffie-Hellman
- should:

Criptare dată - sender - should: 3DES, RC2/40
- receiver - must: 3DES
- should: RC2/40

5. Standarde de Securitate

1. Roluri și tipuri

Rol - asigurarea interoperabilității

Tipuri - de jure (FIPS, ANSI)
de facto (PKCS)

2. Organizații de standardizare

a) Internaționale

- Internet Society (IAB, IETF, IESG, RFC) crează RFC
- International Telecommunication Union (ITU) (Radiocom., Telecom., Aeronaut.)
- IEEE - pt criptografi și rețele
- ISO - pt securitate și criptografie

b) Naționale

- ANSI (USA)
- BSI (UK)
- AFNOR (FR)
- DIN (DE)
- NIST (USA)

3. Standardele Majore

1. IETF - Auth, TLS, IPsec
- securitate automată,
protecție împotriva DOS

2. ITU - standardele X.509 (framework pt auth)
X.800 (arh. securității OSI)
X.736 (alarme de securit.)

3. IEEE P1363 - criptografie cu cheie publică
802.1X - control de acces la rețea
802.11i - securitate în rețele wireless

4. EESSI - pt semnătură electronică

5. ISO

- 27000 - managementul securității info.
- 7498-2 - modelul OSI de securitate
- 9497 - MAC
- 11770 - managementul cheilor criptografice
- 13888 - Non-repudiare
- 14888 - semnături digitale

6. ANSI

- X9.23 - DES
- X9.30 - standard de semnătură dig.
- X9.42 - acord de chei Diffie-Hellman
- X9.62 - alg. ECDSA

7. NIST

- FIPS 46-2 DES
- 197 AES
- 186 DSS
- 198 HMAC

8. RSA Labs.

- PKCS #1 Standard RSA
- PKCS #3 Diffie-Hellman
- PKCS #5 criptografie bazată pe parolă
- PKCS #7 mesaje criptografice
- PKCS #11 format de info. pt tokenuri criptografice
- PKCS #15